



ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN

CƠ SỞ HẠ TẦNG CÔNG NGHỆ THÔNG TIN

Biên soạn: ThS. Nguyễn Thị Anh Thư

Email: thunta@uit.edu.vn



ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN

Chương 7

Bảo mật hạ tầng và quản trị rủi ro

Biên soạn: ThS. Nguyễn Thị Anh Thư

Email: thunta@uit.edu.vn



Nội dung

I. Khái niệm an toàn thông tin và mô hình CIA

II. Kiểm soát truy cập, xác thực, phân quyền

III. Rủi ro phổ biến và nguyên tắc giảm thiểu

IV. Tổng kết



I. Khái niệm an toàn thông tin và mô hình CIA

1. Khái niệm an toàn thông tin
2. CIA Triad: Ba trụ cột của an toàn thông tin
3. Confidentiality – Tính bảo mật
4. Integrity – Tính toàn vẹn
5. Availability – Tính sẵn sàng



1. Khái niệm an toàn thông tin

An toàn thông tin là quá trình bảo vệ dữ liệu, hệ thống, dịch vụ và hạ tầng CNTT khỏi các hành vi truy cập trái phép, thay đổi bất hợp pháp, gián đoạn dịch vụ hoặc phá hoại.

- Bảo vệ dữ liệu và tài nguyên số.
- Ngăn chặn truy cập trái phép.
- Đảm bảo hệ thống hoạt động ổn định.
- Giảm thiểu thiệt hại khi xảy ra sự cố bảo mật.
- Gắn bảo mật với hoạt động quản trị rủi ro.

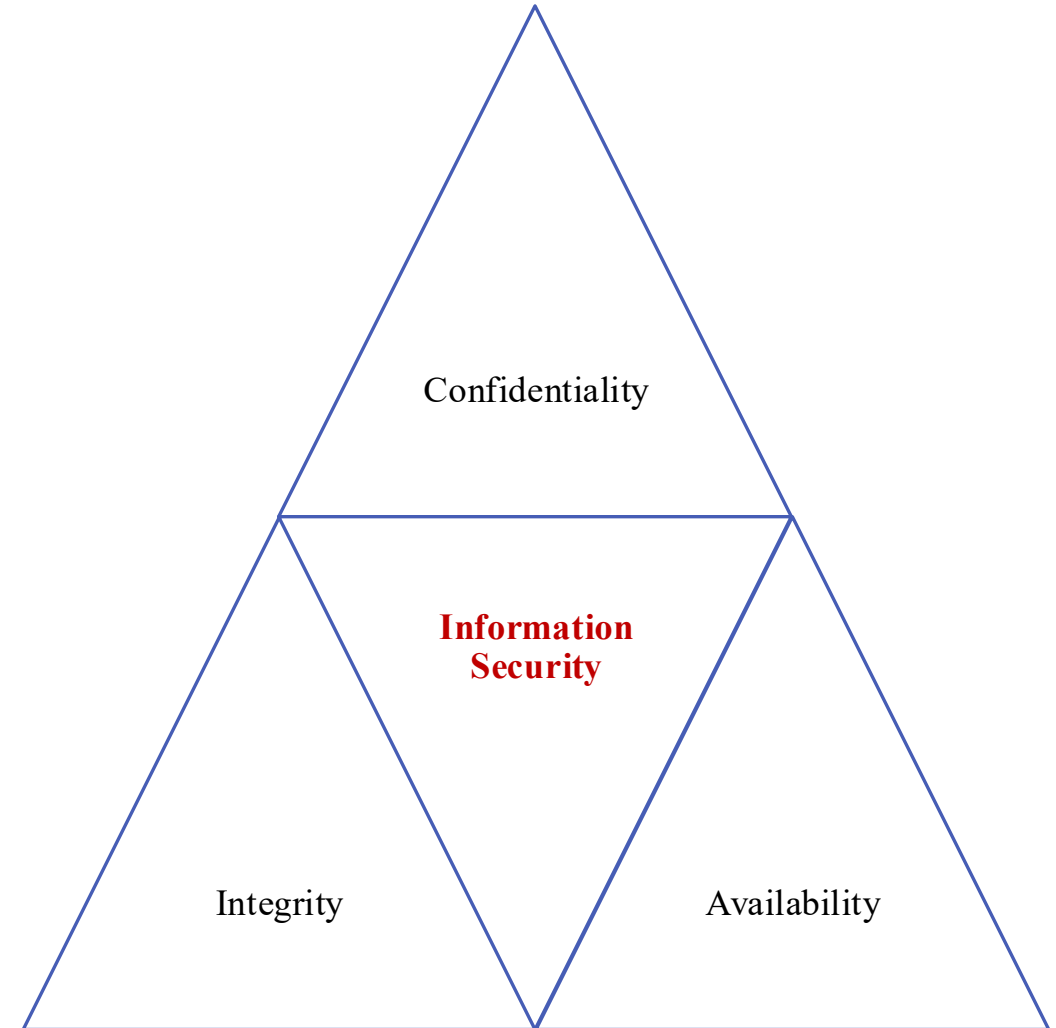
Ví dụ minh họa:

- Tài khoản sinh viên bị đánh cắp mật khẩu.
- Website trường học bị tấn công làm gián đoạn truy cập.
- Cơ sở dữ liệu điểm bị chỉnh sửa trái phép.

2. CIA Triad: Ba trụ cột của an toàn thông tin

CIA là mô hình nền tảng trong an toàn thông tin, gồm:

Thành phần	Ý nghĩa	Ví dụ
Confidentiality	Bảo mật, giữ bí mật thông tin	Chỉ người có quyền mới xem được dữ liệu
Integrity	Toàn vẹn, đảm bảo dữ liệu không bị sửa sai	Điểm số không bị thay đổi trái phép
Availability	Sẵn sàng, đảm bảo hệ thống luôn truy cập được	Website hoạt động ổn định khi có nhiều người dùng





3. Confidentiality – Tính bảo mật

Confidentiality đảm bảo thông tin chỉ được truy cập bởi đúng người, đúng vai trò và đúng phạm vi quyền hạn.

- Ngăn truy cập trái phép vào dữ liệu.
- Bảo vệ thông tin cá nhân, tài khoản, hồ sơ, dữ liệu tài chính.
- Áp dụng mã hóa, xác thực, phân quyền, chính sách mật khẩu.

Ví dụ:

- Mật khẩu người dùng được mã hóa trong cơ sở dữ liệu.
- Hồ sơ sinh viên chỉ được xem bởi phòng đào tạo và giảng viên có quyền.
- File quan trọng được giới hạn quyền truy cập.



4. Integrity – Tính toàn vẹn

Integrity đảm bảo dữ liệu chính xác, đầy đủ và không bị thay đổi trái phép trong quá trình lưu trữ, truyền tải hoặc xử lý.

- Ngăn sửa đổi dữ liệu trái phép.
- Phát hiện dữ liệu bị thay đổi bất thường.
- Sử dụng chữ ký số, checksum, log hệ thống, kiểm soát phiên bản.

Ví dụ:

- Điểm thi không được sửa nếu không có quyền.
- File tải về có mã kiểm tra hash để xác minh tính toàn vẹn.
- Nhật ký hệ thống ghi nhận ai đã thay đổi dữ liệu và thay đổi khi nào.



5. Availability – Tính sẵn sàng

Availability đảm bảo hệ thống, dữ liệu và dịch vụ luôn sẵn sàng khi người dùng hợp lệ cần sử dụng.

- Duy trì hoạt động ổn định của hệ thống.
- Giảm thời gian gián đoạn dịch vụ.
- Sử dụng sao lưu, dự phòng, cân bằng tải, chống tấn công từ chối dịch vụ.

Ví dụ:

- Website đăng ký học phần phải hoạt động trong thời gian cao điểm.
- Hệ thống có máy chủ dự phòng khi máy chủ chính gặp sự cố.
- Dữ liệu có thể khôi phục khi bị lỗi ổ cứng hoặc ransomware.



II. Kiểm soát truy cập, xác thực, phân quyền

1. Kiểm soát truy cập
2. Xác thực và phân quyền
3. Sao lưu dữ liệu
4. Cập nhật và vá lỗi



1. Kiểm soát truy cập

Kiểm soát truy cập là quá trình xác định ai được phép truy cập vào tài nguyên nào và được thực hiện hành động gì.

- Quản lý quyền truy cập vào hệ thống, ứng dụng, cơ sở dữ liệu.
- Áp dụng nguyên tắc **least privilege**: chỉ cấp quyền tối thiểu cần thiết.
- Theo dõi và ghi log hoạt động truy cập.
- Thu hồi quyền khi người dùng không còn nhiệm vụ liên quan.

Ví dụ:

- Sinh viên chỉ được xem điểm của mình.
- Giảng viên được nhập điểm cho lớp mình phụ trách.
- Quản trị viên có quyền cấu hình hệ thống nhưng cần được giám sát.

2. Xác thực và phân quyền

Vai trò	Quyền truy cập
Admin	Quản lý toàn bộ hệ thống
Giảng viên	Quản lý lớp học, nhập điểm
Sinh viên	Xem thông tin cá nhân, đăng ký học phần
Khách	Chỉ xem thông tin công khai

Xác thực trả lời câu hỏi: “Bạn là ai?”

Phân quyền trả lời câu hỏi: “Bạn được phép làm gì?”

- Xác thực bằng mật khẩu, OTP, sinh trắc học, xác thực đa yếu tố.
- Phân quyền theo vai trò: Admin, Manager, Staff, User.
- Phân quyền theo tài nguyên: file, database, API, hệ thống.
- Hạn chế dùng chung tài khoản quản trị.



3. Sao lưu dữ liệu

Sao lưu giúp khôi phục dữ liệu khi xảy ra sự cố như mất dữ liệu, lỗi phần cứng, ransomware hoặc thao tác nhầm.

- Sao lưu định kỳ dữ liệu quan trọng.
- Lưu bản sao ở nhiều vị trí khác nhau.
- Kiểm tra khả năng khôi phục dữ liệu.
- Áp dụng nguyên tắc **3-2-1 backup**:
 - 3 bản sao dữ liệu.
 - 2 loại thiết bị/lưu trữ khác nhau.
 - 1 bản sao đặt ngoài hệ thống chính hoặc trên cloud.

Ví dụ:

- Sao lưu cơ sở dữ liệu mỗi ngày.
- Lưu bản backup trên server nội bộ và cloud.
- Kiểm tra khôi phục dữ liệu theo định kỳ hàng tháng.



4. Cập nhật và vá lỗi

Cập nhật/vá lỗi là quá trình sửa các lỗ hổng bảo mật trong hệ điều hành, phần mềm, thư viện, framework và thiết bị mạng.

- Phần mềm lỗi thời dễ bị khai thác.
- Cần cập nhật hệ điều hành, antivirus, trình duyệt, server, database.
- Kiểm tra bản vá trước khi triển khai trên hệ thống thật.
- Ưu tiên vá các lỗ hổng nghiêm trọng.

Ví dụ:

- Cập nhật Windows/Linux server.
- Vá lỗi Apache, Nginx, MySQL, PHP, Node.js.
- Cập nhật plugin CMS như WordPress để tránh bị chiếm quyền.

III. Rủi ro phổ biến và nguyên tắc giảm thiểu

1. Malware
2. Phishing
3. Lộ dữ liệu
4. Cấu hình sai
5. Nguyên tắc giảm thiểu rủi ro
6. Quy trình quản trị rủi ro bảo mật
7. Tình huống



1. Malware

Malware là phần mềm độc hại được thiết kế để xâm nhập, phá hoại, đánh cắp dữ liệu hoặc kiểm soát hệ thống.

Các loại phổ biến:

- Virus.
- Worm.
- Trojan.
- Ransomware.
- Spyware.

Biện pháp giảm thiểu:

- Cài phần mềm chống mã độc.
- Không tải file từ nguồn không tin cậy.
- Không mở file đính kèm đáng ngờ.
- Cập nhật hệ điều hành và phần mềm.
- Sao lưu dữ liệu định kỳ.



2. Phishing

Phishing là hình thức lừa đảo nhằm đánh cắp thông tin nhạy cảm như tài khoản, mật khẩu, mã OTP hoặc thông tin tài chính.

Dấu hiệu nhận biết:

- Email yêu cầu đăng nhập gấp.
- Đường link giả mạo gần giống website thật.
- File đính kèm bất thường.
- Nội dung tạo cảm giác khẩn cấp hoặc đe dọa.

Biện pháp giảm thiểu:

- Kiểm tra kỹ địa chỉ email và URL.
- Không nhập mật khẩu qua link lạ.
- Sử dụng xác thực đa yếu tố.
- Tập huấn nhận diện phishing cho người dùng.
- Báo cáo email đáng ngờ cho bộ phận IT.



3. Lộ dữ liệu

Lộ dữ liệu xảy ra khi thông tin nhạy cảm bị truy cập, tiết lộ hoặc phát tán trái phép.

Nguyên nhân thường gặp:

- Phân quyền sai.
- Mật khẩu yếu hoặc bị lộ.
- Cấu hình cloud sai.
- Thiếu mã hóa dữ liệu.
- Nhân viên gửi nhầm thông tin.

Biện pháp giảm thiểu:

- Mã hóa dữ liệu quan trọng.
- Kiểm soát quyền truy cập.
- Ghi log và giám sát truy cập.
- Phân loại dữ liệu theo mức độ nhạy cảm.
- Có quy trình xử lý sự cố rò rỉ dữ liệu.



4. Cấu hình sai

Cấu hình sai là một trong những nguyên nhân phổ biến gây mất an toàn hệ thống.

Ví dụ:

- Mở cổng dịch vụ không cần thiết.
- Để mật khẩu mặc định.
- Cho phép public database hoặc storage bucket.
- Cấu hình sai firewall.
- Bật debug mode trên môi trường production.

Biện pháp giảm thiểu:

- Áp dụng checklist cấu hình an toàn.
- Tắt dịch vụ không sử dụng.
- Thay đổi mật khẩu mặc định.
- Kiểm tra cấu hình định kỳ.
- Tự động quét lỗi cấu hình bằng công cụ bảo mật.



5. Nguyên tắc giảm thiểu rủi ro

Các nguyên tắc cơ bản:

- **Least Privilege:** cấp quyền tối thiểu cần thiết.
- **Defense in Depth:** bảo vệ nhiều lớp.
- **Zero Trust:** không mặc định tin cậy bất kỳ người dùng hoặc thiết bị nào.
- **Backup and Recovery:** luôn có kế hoạch sao lưu và khôi phục.
- **Patch Management:** cập nhật và vá lỗi thường xuyên.
- **Monitoring and Logging:** giám sát và ghi nhận hoạt động hệ thống.
- **Security Awareness:** nâng cao nhận thức người dùng.





6. Quy trình quản trị rủi ro bảo mật

Quy trình 5 bước:

- **Identify** – Nhận diện tài sản và rủi ro.
- **Assess** – Đánh giá khả năng xảy ra và mức độ ảnh hưởng.
- **Mitigate** – Áp dụng biện pháp giảm thiểu.
- **Monitor** – Giám sát liên tục.
- **Review** – Đánh giá và cải tiến định kỳ.

Rủi ro	Khả năng	Tác động	Biện pháp
Phishing	Cao	Cao	MFA, đào tạo người dùng
Mất dữ liệu	Trung bình	Cao	Backup, phân quyền
Malware	Cao	Cao	Antivirus, cập nhật, kiểm soát file
Cấu hình sai	Trung bình	Cao	Checklist, audit định kỳ



7. Tình huống

Một doanh nghiệp nhỏ sử dụng website bán hàng. Hệ thống bị tấn công ransomware làm mã hóa toàn bộ cơ sở dữ liệu khách hàng và đơn hàng.

- Rủi ro nào đã xảy ra?
- Thành phần nào của CIA bị ảnh hưởng?
- Nguyên nhân có thể là gì?
- Doanh nghiệp cần chuẩn bị biện pháp nào trước khi sự cố xảy ra?
- Sau sự cố, cần thực hiện các bước khắc phục nào?

Gợi ý:

- Rủi ro: malware/ransomware.
- CIA bị ảnh hưởng: Availability và Integrity.
- Biện pháp: backup, cập nhật hệ thống, kiểm soát email, phân quyền, giám sát truy cập.



IV. Tổng kết

- An toàn thông tin dựa trên ba nguyên tắc cốt lõi: Confidentiality, Integrity, Availability.
- Bảo mật hạ tầng cần kết hợp giữa kỹ thuật, quy trình và con người.
- Kiểm soát truy cập, xác thực, phân quyền, sao lưu và vá lỗi là các biện pháp nền tảng.
- Malware, phishing, lộ dữ liệu và cấu hình sai là các rủi ro phổ biến cần được nhận diện sớm.
- Quản trị rủi ro là quá trình liên tục: nhận diện, đánh giá, giảm thiểu, giám sát và cải tiến.

Q & A
